

HiveForce Labs

THREAT ADVISORY

ATTACK REPORT

NeedleDropper malware leverages a memory corruption flaw in Microsoft to disseminate

Date of Publication

January 12, 2023

Admiralty Code

A1

TA Number

TA2023020

Summary

First appeared: October 2022

Attack Region: Worldwide

Attack: A new dropper strain designated "NeedleDropper," is being employed by attackers to obscure malicious payloads and exploit the CVE-2017-11882 vulnerability to mount sophisticated payloads.

Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

CVE

CVE	NAME	PATCH
CVE-2017-11882	Microsoft Office Memory Corruption Vulnerability	

Attack Details

#1

A new dropper strain dubbed NeedleDropper is used to distribute multiple malware families. The dropper attempts to obfuscate by dumping numerous useless, invalid files and storing critical data within several MB of irrelevant data, and it also uses credible applications to execute.

#2

NeedleDropper is a self-extracting package that includes a modified Autolt interpreter, a simplified Autolt script, and a Visual Basic script. The Autolt script is used for initial execution and is passed as a parameter to the Autolt interpreter when the malware is launched.

#3

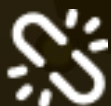
The dropper, primarily distributed through spam email attachments, contains an Excel document that takes advantage of the CVE-2017-11882 vulnerability to launch the vbc.exe (NeedleDropper) file, which then unloads its content into a temporary folder. After that, the dropper decrypts the FormBook payload and injects it into the RegSvcs process, allowing it to be executed.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation
<u>TA0005</u> Defense Evasion	<u>T1547</u> Boot or Logon Autostart Execution	<u>T1176</u> Browser Extensions	<u>T1027</u> Obfuscated Files or Information
<u>T1566</u> Phishing	<u>T1059</u> Command and Scripting Interpreter	<u>T1055</u> Process Injection	<u>T1140</u> Deobfuscate/Decode Files or Information
<u>T1505</u> Server Software Component			

Indicators of Compromise (IOCs)

TYPE	VALUE
SHA256	660eb5f2811753c24ecbd5c0e08c68d83d7eca1b2827ed90e2a5189ed61f3a5b,f7e52f120ab257e0d8e5021077b3370876be16469b76b6e0b6916486b3977bb3,06b02574925948a3f418ba2851f10585086a5f9b25d8f4e7de62dd52c6a56153,e53e5e07b3165f507046c5992049a816bdd98969f10cc97a3d2bd010aea30b42,1b26f3213c07819cd61ed5e10b009ae5862cade4a3a403dcc6f6310485f6306b,1d3078201c04bebc6595a2cc874530f1c2a5ff7201db4c8e43660808563c5a63,dd7acb0d5e05d581148b614816f5450690f3fcc8ba4b3f00b5db1f3684570053,8713d873a8f4179a4079ea46a6ae45a538dc2f07cf7b09f28adc25eec45dc873,01534a0f3e104b7cbafefeeaac3a0f0bf9d01e017c8a63964d81d0a30baee2916

Patch Link

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2017-11882>

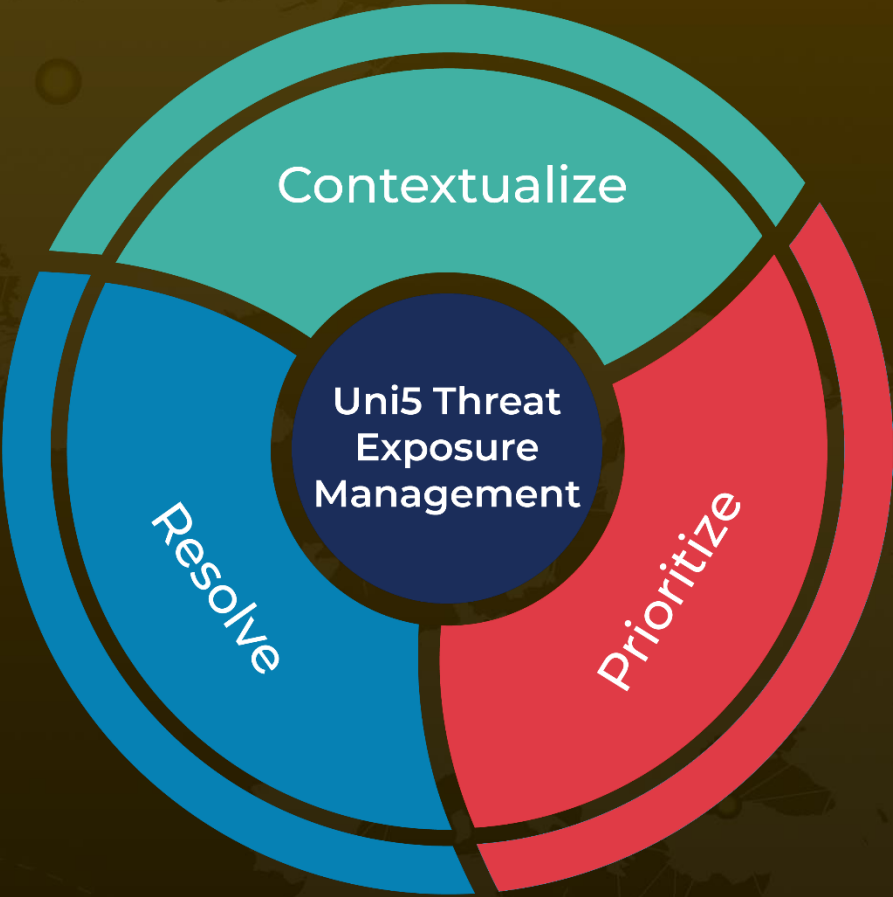
References

<https://decoded.avast.io/threatresearch/needledropper/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

January 12, 2023 • 12:33 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com